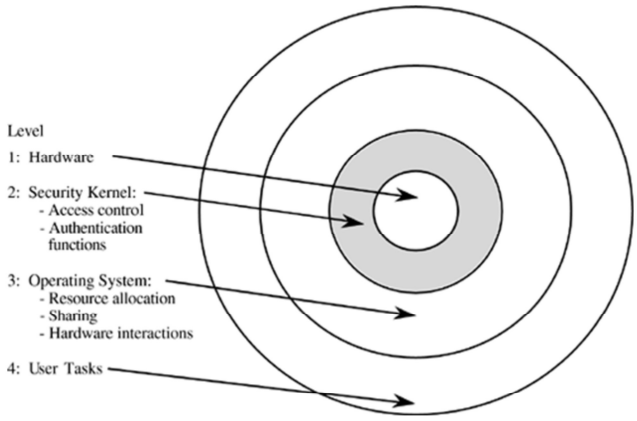
Security Kernel or Reference Monitor

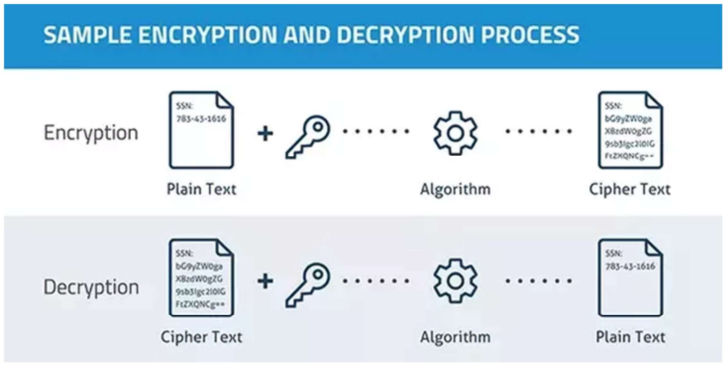


© 2018 Al-Nafi. All Rights Reserved.

The security kernel or "reference monitor" within an operating system or hardware device, acts as a security oversight mechanism that enforces a predefined set of rules when a subject accesses an object. The rules may include validating permissions from a table (e.g., DAC) but are mandatorily applied and designed to prevent being bypassed.

However, when user subjects are executing with administrative rights on a system (e.g., Windows Administrator, Linux/Unix root), the subject often has full control of most system objects. The security kernel will still operate, but it will lose effectiveness when the subject has full security rights to all objects. To maximize the effectiveness of the security kernel, user subjects must be executed with the least privilege necessary to perform their intended function.

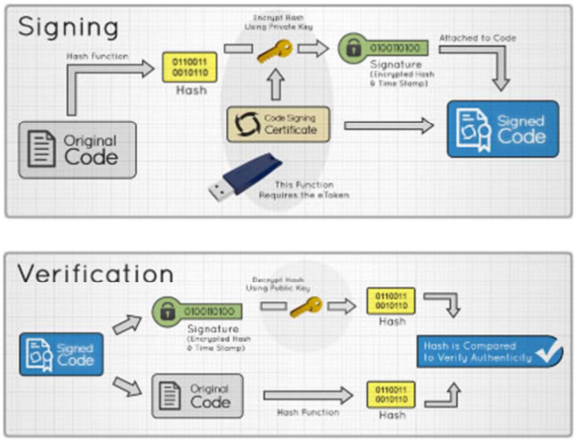
Encryption



© 2018 Al-Nafi. All Rights Reserved.

Encryption can be applied to data at rest (e.g., files on hard drive) or data in transit (e.g., communication channel). Encryption may be used to protect confidentiality, integrity, or both concurrently. The most direct value of encryption is the protection of data while the operating system protections are not active or available. For example, encrypted data may be stored on a hard drive. If the computer system is turned off and the hard drive removed, the data cannot be read or modified since it is encrypted. Also, once data has been transmitted from the system, if encrypted, it is protected from access or modification if intercepted in transit. The specific protections (confidentiality, integrity) and level of protection provided by encryption varies depending on the specific cryptographic mechanism utilized.

Code Signing and Validation



© 2018 Al-Nafi. All Rights Reserved.

Code signing and validation is a cryptographic function. Executable code is digitally signed using mechanisms presented in this module. This allows an operating system, firmware, or even hardware components to validate the digital signature on the executable code prior to it being loaded for execution. This ensures that only known, approved code is able to execute on a system or device.

In some operating systems, the system checks the OS components before they are loaded. This helps to prevent unauthorized code replacing legitimate system components and being executed at a higher privilege level than would normally be granted to user code.

Code signing may also be used during system or component updates or when loading new software to ensure that the copy being loaded is an approved copy from a recognized source. The protects the system from loading malicious or unapproved code presented as legitimate code.

Audit and Monitoring

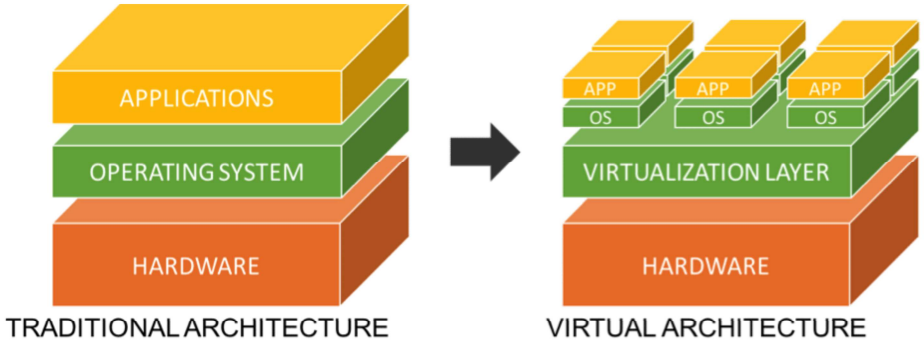


© 2018 Al-Nafi. All Rights Reserved.

Secure systems must also have the ability to provide administrators with evidence of their correct operation. This is performed using logging subsystems that allow for important system, security, and application messages to be recorded for analysis. More secure systems will provide considerable protection to ensure these logs cannot be tampered with, including secure export of such logs to external systems.

As part of an organizational security architecture, logs and monitoring data must be collected from individual systems and reviewed by automated or manual means. This is typically done centrally where data from multiple systems can be used to build an overall protection picture of the entire information environment. Logs that are not reviewed or managed, either by automated or manual means, provide some value to correct issues after they have occurred. By monitoring logs and information systems, the audit data can provide some preventative and detective control value as well.

Virtualization/Sandbox



© 2018 Al-Nafi. All Rights Reserved.

Virtualization offers numerous advantages from a security perspective. Virtual machines are typically isolated in a sandbox environment and if infected can be removed quickly or shut down and replaced by another virtual machine. The sandbox environment is intentionally designed to keep executing code within the controlled sandbox space and limit communications into or out of the sandbox.

Virtual machines:

Have limited access to hardware resources and, therefore, help protect the host system and other virtual machines

Do require strong configuration management control and versioning to ensure known good copies are available for restoration if needed

Are also subject to all the typical requirements of hardware based systems, including anti-malware software, encryption, host intrusion detection system (HIDS), firewalls, and patching.

Some operating systems automatically, or can be configured to, sandbox certain types of code. Mobile code (e.g., Java, ActiveX, etc.) may be allowed only to execute in a controlled sandbox where the system configuration controls how much or little

access to the rest of the system is possible for code executing within the sandbox.